HAL Guardian

EXECUTIVE SUMMARY

Local-first AI security assistant | Proof of concept | July 21, 2026

Executive Overview

HAL Guardian is a local-first security assistant that reviews code and untrusted content, compares local AI models, exposes checks to other agents, and preserves an on-device audit trail. Its core proposition is useful AI-assisted security without making cloud services the default trust boundary.

Core Capabilities

Code Guardian
Reviews uploaded or pasted code and returns a verdict, summary, severity-ranked findings, recommendations, and JSON/Markdown exports.

Trust Shield
Detects prompt injection, hidden commands, and encoded payloads using deterministic checks plus an optional local-model deep scan.

Model Playground
Chats with local Ollama models, compares two responses, and can use a selected model to judge task performance.

Sub-Agent Console
Lets external agents call modules through predictable commands and receive standardized JSON response envelopes.

Audit, Health & Settings
Maintains local action/error records, confirms model and storage health, and controls optional web access and allowlists.

How It Works

1. User or external agent submits code, text, a prompt, document, or approved URL.
2. Streamlit and Python modules prepare prompts, run deterministic checks, and call Ollama.
3. A local Gemma model analyzes the material through a localhost endpoint.
4. HAL Guardian parses structured findings while preserving the full model response for verification.
5. Results are reviewed by a human, exported if needed, and logged locally; fixes are never applied automatically.

Controls & Requirements

- Data, inference, prompts, logs, settings, and allowlists stay local by default.
- Web fetching is off by default, allowlisted, warning-gated, and requires confirmation.
- Requires a capable machine, Ollama, a local Gemma model, the Streamlit/Python application, and local SQLite/JSONL storage.
- Deep scans and model comparisons add latency.

Why It Matters

HAL Guardian combines code review, untrusted-input classification, model evaluation, agent-to-agent delegation, auditability, and health monitoring in one controlled local interface. The most valuable design choice is the combination of on-device AI, structured outputs, and explicit human approval gates - a pattern that can support privacy-sensitive software and agent workflows.

PRIVATE BY DEFAULT
No API keys, telemetry, or remote inference are required for the demonstrated workflow.

HUMAN-CONTROLLED
Model suggestions remain advisory; users inspect outputs and apply changes themselves.

INTEGRATION-READY
Structured JSON and audit records can feed CI, ticketing, agent, or secondary-review processes.

IMPORTANT LIMITATION

This is a proof of concept, not a production security product. The demo does not establish production hardening, benchmark accuracy, regulatory compliance, or replacement of professional security review.